

Oversight of Notification of Breach of Personal Data Security

Date: 31-08-2023

Decision

Public Authorities

Criticism

Supervision / Self-initiated Case

Unintentional Disclosure

Notification of Breach of Personal Data Security

The Data Protection Agency has conducted 16 scheduled inspections focusing on municipalities' and banks' handling of breaches of personal data security. The Data Protection Agency found reason to express criticism in two cases.

Journal Number: 2021-423-0247.

Frederikshavn Municipality was among the public authorities that the Data Protection Agency selected for oversight in the spring of 2021, in accordance with the General Data Protection Regulation [1] and the Data Protection Act [2].

The Data Protection Agency's oversight was a written inspection that focused on whether Frederikshavn Municipality reports and documents breaches of personal data security in accordance with Article 33, paragraph 1, and Article 33, paragraph 5 of the General Data Protection Regulation, including the municipality's processes for handling and recording breaches of personal data security. The oversight was based on an assessment of samples among unreported breaches as well as information about guidelines, procedures, and training activities, etc.

The oversight was announced to Frederikshavn Municipality by letter dated June 21, 2021, and the municipality was simultaneously requested to answer a series of questions. The Data Protection Agency informed about the background for the oversight, noting that a review of the oversight's cases regarding notifications of breaches of personal data security revealed that Frederikshavn Municipality had reported significantly fewer breaches of personal data security per inhabitant in the municipality than other municipalities in Denmark.

By letter dated August 24, 2021, Frederikshavn Municipality sent a statement in which the municipality responded to the Data Protection Agency's questions. The municipality's response was also accompanied by a number of documents, including process descriptions and guidelines that the municipality uses to comply with Article 33 of the General Data Protection Regulation.

Summary

In the summer and autumn of 2021, the Data Protection Agency initiated written inspections of the handling of breaches of personal data security by eight larger municipalities and eight larger banks. The inspections were organized so that the municipalities and banks were divided into two groups – those that had reported the most and the fewest breaches in relation to the municipalities' population and the number of employees in the banks.

"One of the new things that came with GDPR over five years ago was that data controllers, as a general rule, must report all breaches of personal data security to the Data Protection Agency within 72 hours, and they must also internally document all breaches of personal data security, regardless of whether they need to be reported to the Data Protection Agency or not. Furthermore, there has been an increased focus on what companies and authorities need to consider when customers' or citizens' information is mishandled by mistake," says Vibeke Dyssemark Thomsen, chief consultant at the Data Protection Agency, and continues: "This can, for example, lead to the need to implement new or additional security measures to reduce the risk of further breaches. Therefore, we have now conducted a service review of the area, where we have looked at the procedures and taken some samples. The conclusion is broadly that the 16 selected municipalities and banks seem to have the right focus on complying with the rules."

Group with the Most Reported Breaches

For the group with the most reported breaches, the inspections focused, among other things, on whether the municipalities and banks had taken appropriate security measures to reduce the number

of breaches of personal data security, where there had been unauthorized disclosure of personal data in connection with the transmission of information to, among others, citizens, authorities, etc., including in relation to citizens with name and address protection and financial information.

Compliance with the rules on appropriate processing security will normally entail that:

The data controller must ensure that information about data subjects, including particularly confidential and sensitive personal data, does not come to the knowledge of unauthorized persons. In this regard, the data controller must ensure that all employees in the organization are, to the necessary extent, familiar with any internal procedures for handling personal data, including in relation to the transmission of personal data to, among others, citizens, authorities, etc.

Procedures, guidelines, workflows, technical security measures, etc. are continuously updated or introduced, including as a result of identified breaches of personal data security.

The Data Protection Agency found on the basis of the information available that all the data controllers had taken appropriate security measures. In its assessment, the Data Protection Agency emphasized that:

Procedures, etc. had been developed and activities had been conducted to educate employees in data protection, including to ensure that they are aware that there should be no unintentional disclosure of personal data to an incorrect recipient.

They have made considerations and continuously implemented both technical and organizational measures following past breaches of personal data security to avoid similar breaches.

There is a strong focus on avoiding unintentional disclosure of confidential information, which is supported both by business processes, ongoing guidance, etc., and systematic measures, etc.

****Group with the Fewest Reported Breaches****

For the group with the fewest reported breaches, the inspections focused on whether municipalities and banks report and document breaches of personal data security in accordance with the requirements of the General Data Protection Regulation (GDPR), including their processes for handling and recording breaches of personal data security.

The Data Protection Authority stated in these cases that it is the Authority's view that compliance with the rules that breaches of personal data security must, as a general rule, be reported to the Data Protection Authority within 72 hours entails that:

1. The data controller must establish appropriate procedures and guidelines to ensure that breaches are detected and handled correctly.
2. In this regard, the data controller must ensure that all employees in the organization are familiar with internal procedures for handling breaches of personal data security to the necessary extent, and that relevant employees can identify, manage, and assess breaches of personal data security.

The Data Protection Authority found that all data controllers, overall, have adopted appropriate procedures and guidelines, etc., and have implemented appropriate training activities that can support compliance with the requirements of the GDPR regarding the reporting of breaches of personal data security. Thus, they can ensure that breaches of personal data security are captured within the organization so that these can be assessed to determine whether the breach should be reported to the Data Protection Authority, as well as to document the breaches, including the reasons for not reporting them to the Data Protection Authority.

However, the Data Protection Authority noted in relation to all inspections that the Authority had not had the opportunity, as part of the inspection, to specifically assess whether all relevant employees have completed the relevant training activities, and that the Authority is not familiar with the full content of the training material, including the content of, for example, ongoing awareness initiatives.

Furthermore, the Data Protection Authority stated that the rule requiring the data controller to document all breaches of personal data security, including the actual circumstances of the breach, its effects, and the remedial measures taken, must ensure that the Data Protection Authority can verify that the provision regarding the reporting of breaches of personal data security is complied with. Therefore, data controllers should document their justifications for all significant decisions made as a result of the breach. This is particularly relevant if the data controller, after assessing the breach,

concludes that it does not need to be reported to the Data Protection Authority. The documentation should, in relation to this decision, include a detailed explanation of why the data controller believes that the breach is unlikely to result in a risk to the rights and freedoms of natural persons.

****Criticism in Two Cases****

As mentioned, there is pronounced criticism in two of the cases – specifically regarding two municipalities that did not document all breaches of personal data security.

In one case, the Data Protection Authority expressed serious criticism of Roskilde Municipality for not documenting how many breaches of personal data security the municipality has identified during the period from May 25, 2018, to September 2019, and that the municipality cannot document whether the recorded security incidents since September 2019 constitute actual breaches of personal data security.

In the other case, the Data Protection Authority criticized Frederikshavn Municipality for not documenting how many breaches of personal data security the municipality identified in 2018.

The Data Protection Authority notes that the list of breaches – in addition to serving as documentation for the Data Protection Authority – should also be used by the data controller to gain an overview of which breaches typically occur in the organization, and based on that, to consider whether, from a risk assessment perspective, there is a need to implement new or supplementary measures to avoid or further reduce the risk of additional breaches. It also appears from the received consultation responses that several data controllers actively use the lists for this purpose.

****1. Decision****

After reviewing the submitted material, the Data Protection Authority finds grounds to express criticism of Frederikshavn Municipality for not documenting how many breaches of personal data security the municipality identified in 2018, cf. Article 33(5) of the General Data Protection Regulation.

Furthermore, the Data Protection Authority finds that Frederikshavn Municipality has, overall, adopted appropriate procedures and guidelines and has implemented appropriate training activities to correctly capture and handle breaches of personal data security, cf. Article 33 of the General Data Protection Regulation.

Below follows a detailed review of the information that has emerged in connection with the inspection, and a justification for the Data Protection Authority's decision.

****2. Justification for the Data Protection Authority's Decision****

****2.1. Relevant Legal Provisions****

A breach of personal data security is defined in Article 4(12) of the General Data Protection Regulation as a breach of security that leads to accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to...

****Personal Data, Transmitted, Stored, or Otherwise Processed.****

It follows from Article 33, paragraph 1 of the Data Protection Regulation that in the event of a breach of personal data security, the data controller must notify the supervisory authority competent in accordance with Article 55 (the Data Protection Authority) without undue delay and, if possible, no later than 72 hours after the data controller becomes aware of the breach of personal data security, unless it is unlikely that the breach of personal data security poses a risk to the rights or freedoms of natural persons. If the notification to the supervisory authority is not made within 72 hours, it must be accompanied by a justification for the delay.

The Data Protection Authority is of the opinion that the requirement in Article 33 for breaches of personal data security to be reported to the Data Protection Authority within 72 hours implies that the data controller must establish appropriate procedures and guidelines to ensure that breaches are detected and handled correctly. In this regard, the data controller must ensure that all employees in the organization are adequately familiar with internal procedures for handling breaches of personal data security, and that relevant employees can identify, manage, and assess breaches of personal data security.

Furthermore, it follows from Article 33, paragraph 5 of the Data Protection Regulation that the data

controller must document all breaches of personal data security, including the actual circumstances of the breach, its effects, and the remedial measures taken. This documentation must enable the supervisory authority (the Data Protection Authority) to verify that the provision has been complied with.

In the Data Protection Authority's guidance from February 2018 on handling breaches of personal data security, it is stated on page 27 that the requirements for documentation can be outlined as follows:

1. Date and time of the breach.
2. What happened in connection with the breach?
3. What is the cause of the breach?
4. What (types of) personal data are covered by the breach?
5. What consequences does the breach have for the affected individuals?
6. What remedial measures have been taken?
7. Whether – and if so how – notification has been made to the Data Protection Authority? Why/why not?

The data controller should thus document its justifications for all significant decisions made as a result of the breach. This is particularly important if the data controller, after assessing the breach, concludes that it does not need to be reported to the Data Protection Authority. The documentation should, in relation to this decision, include a detailed explanation of why the data controller believes that the breach is unlikely to result in a risk to the rights and freedoms of natural persons.

****2.2. Documentation of Breaches of Personal Data Security****

Frederikshavn Municipality has stated in its statement of August 24, 2021, that since May 25, 2018, a total of 34 breaches of personal data security have been recorded in the municipality. However, Frederikshavn Municipality further stated that it has not been possible to find an incident log for 2018, but that a single breach of personal data security has been recorded for that year.

The Data Protection Authority therefore assumes that Frederikshavn Municipality has only documented information security incidents in an incident log since 2019, and that the municipality has thus not documented all breaches of personal data security since May 25, 2018, when the Data Protection Regulation came into effect.

The Data Protection Authority finds reason to express criticism that Frederikshavn Municipality has not documented how many breaches of personal data security the municipality has identified in 2018, cf. Article 33, paragraph 5 of the Data Protection Regulation.

In choosing a reaction, the Data Protection Authority has emphasized that the lack of documentation only pertains to 2018.

****2.3. Assessment of Non-Reported Breaches****

At the request of the Data Protection Authority, Frederikshavn Municipality has accounted for the first three breaches of personal data security that occurred in 2021, which the municipality failed to report to the Data Protection Authority.

The first incident involved a caseworker sending a psychological assessment regarding an incorrect citizen to the Appeals Board. The Appeals Board was contacted and stated that the incorrect document had been deleted. The second incident involved an employee mistakenly sending a cancellation regarding an AOK process on behalf of a citizen to an HK project employee before a data processing agreement had been entered into with HK. The email contained the name and date of birth of the data subject. The HK project employee, who was to process such personal data once the data processing agreement was in place, deleted the email immediately. The third incident involved an employee in the Placement Office for Daycare sending an email to a citizen instead of a colleague. It contained the first name and income information of the data subject. The recipient was immediately requested to delete the email, and the deletion was confirmed both verbally and via email. The recipient was deemed very trustworthy based on previous collaboration.

The Data Protection Authority finds no basis to override the municipality's assessment that the three incidents can be characterized as breaches of personal data security, cf. Article 4, no. 12 of the Data Protection Regulation, but that these are not subject to the obligation to report.

The Data Protection Authority thus finds no basis to override the assessment that it must be deemed unlikely that the relevant breaches pose a risk to the rights and freedoms of natural persons. risk to the rights and freedoms of natural persons, cf. Article 33, paragraph 1.

The Data Protection Agency notes, however, in relation to the third incident, that the data controller should be certain in their case when the credibility of the recipient is given significance for the assessment of whether notification to the Data Protection Agency should occur, and that the internal documentation of the incident should provide a more detailed justification for this credibility assessment.

2.4. Procedures and Training of Employees

It appears from the statement of August 24, 2021, and the attached appendices, that Frederikshavn Municipality has, among other things, established procedures for where and how breaches of personal data security should be reported internally within the municipality, whom employees can contact with questions about breaches, and who is responsible for handling and assessing breaches as well as for reporting to the Data Protection Agency.

It further appears that Frederikshavn Municipality has developed guidelines and conducted activities aimed at training employees in data protection, including enabling them to identify and potentially handle breaches of personal data security.

Regarding the criteria included in Frederikshavn Municipality's assessment of whether a breach of personal data security should be reported to the Data Protection Agency, Frederikshavn Municipality has stated, among other things, that if the data protection officer is in doubt, the assessment will always be made in favor of the data subject.

Based on the submitted material, including information about the three unreported breaches from 2021 – despite the lack of registration of breaches in 2018 – the Data Protection Agency's immediate assessment is that Frederikshavn Municipality has overall adopted appropriate procedures and guidelines, etc., and has conducted appropriate training activities that can support compliance with the requirements of Article 33 of the General Data Protection Regulation, and which can thereby ensure that breaches of personal data security are captured within the organization, so that these can be assessed to determine whether the breach should be reported to the Data Protection Agency, as well as documentation of the breaches can be made, including, among other things, the justification for not reporting them to the Data Protection Agency.

It is noted that the Data Protection Agency has not had the opportunity, as part of the supervision, to take a specific position on whether all relevant employees have completed the relevant training activities, and that the supervision is not familiar with the full content of the training material, including the content of, for example, ongoing awareness initiatives.

[1] Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data and repealing Directive 95/46/EC (General Data Protection Regulation)

[2] Act No. 502 of May 23, 2018, on supplementary provisions to the regulation on the protection of natural persons in relation to the processing of personal data and on the free movement of such data. (Data Protection Act)